

Cahier des Charges - Cyberspace IoT Security Center

Projet : Prototype IoT de supervision, détection et réponse cyber **Date :** 25 septembre 2026
Technologies : Raspberry Pi (x2), MQTT (Mosquitto), Python, Flask, Docker, CI/CD

1. Vision

Cyberspace Horizon 2080 est un prototype de centre de sécurité inter-systèmes. Il supervise des équipements IoT (capteurs, digicodes) répartis dans un environnement spatial simulé. Il intercepte les signaux MQTT, les chiffre, et les analyse en temps réel pour détecter et bloquer les intrusions.

Chaîne de valeur : équipement → événement MQTT → détection IDS → alerte → réponse automatisée (confinement).

Principes directeurs :

- 1. **Zéro confiance envers le transport.** Tout message MQTT est considéré hostile s'il n'est pas chiffré (AES-128) et protégé par un jeton anti-rejeu.
- 2. **Réponse Autonome.** L'isolement d'un équipement compromis est réalisé instantanément par le serveur, sans intervention humaine requise.
- 3. **Simplicité et robustesse.** Le système fonctionne intégralement en mémoire vive locale (Edge Computing) pour garantir des temps de réponse de l'ordre de la milliseconde.

2. Contexte, hypothèses et contraintes

- Projet réalisé dans le cadre du Workshop Horizon 2080 : équipe de 4, durée courte.
- **Hypothèse H1 :** Un conteneur Docker Mosquitto local sécurisé (identifiants stricts) est le cœur de la communication.
- **Hypothèse H2 :** Le système est déployé sur deux cartes Raspberry Pi. La Board 1 (pi-center) agit comme Serveur Central. La Board 2 agit comme Client IoT (Digicode, Capteur PIR, Terminal de Chat).
- **Contrainte :** Déploiement cible ARM64, réseau Wi-Fi local isolé.

3. Objectifs et priorisation (MoSCoW)

Niveau	Contenu
MUST	

Niveau	Contenu
	Dashboard temps réel, Ingestion MQTT chiffrée, IDS automatique, Détection de messages en clair, Détection de Replay Attacks, Isolation automatique (Watchdog), CI/CD multi-architecture.
SHOULD	Capteur de mouvement physique réel (GPIO), Digicode d'accès physique, Chat sécurisé inter-systèmes.
WON'T	Base de données persistante (SQLite abandonné au profit de la RAM pour les performances), caméras virtuelles, authentification par jetons web API.

4. Architecture Globale

- **Flux Sécurisé** : Capteur (PIR/Digicode) → Chiffrement AES-128 Fernet + Horodatage → MQTT (QoS 1) → Serveur Central → IDS.
- **Composants** :
 - **Serveur Central (Python/Flask)** : Orchestration, Dashboard Web.
 - **Broker (Mosquitto)** : Transport asynchrone sécurisé (identifiants `v-client`).
 - **IDS (Intrusion Detection System)** : Moteur de règles qui lève des alertes `CRITICAL` et isole les IPs/Devices compromis via le pare-feu logiciel.
 - **Couche Physique (Raspberry Pi 2)** : Capteur Infrarouge (PIR) et script digicode interactif bloquant le sas physique.

5. Modèle de Menace & Contre-Mesures

Menace	Impact	Contre-mesure (Implémentée)
Message en clair injecté	Contournement du système	L'IDS détecte l'absence de chiffrement et lève une alerte <code>UNENCRYPTED_PAYLOAD</code> .
Rejeu d'un message capturé	Fausse commande d'ouverture	Le payload inclut un <i>Token</i> horodaté (TTL 300s). L'IDS le rejette (<code>INVALID_TOKEN</code>).
Brute Force (Digicode)	Accès non autorisé au SAS	Le script bloque l'accès physique et remonte l'alerte <code>AUTH_FAILURE</code> au Dashboard.
Intrusion Physique	Sabotage des capteurs	Le capteur PIR détecte un mouvement en zone verrouillée et alerte l'IDS.
Comportement suspect	Spam du réseau MQTT	Le script <code>watchdog.py</code> place l'équipement en quarantaine totale (<code>ISOLATED</code>).

6. Critères de réussite de la Démonstration (5 minutes)

1. **Trafic normal** : Les terminaux communiquent de manière chiffrée et apparaissent "ONLINE" sur le Dashboard.
2. **Capteur Physique** : Déclenchement d'un mouvement sur le capteur PIR sans taper le code 2080 déclenche une alerte au centre de contrôle.
3. **Attaque Simulée** : Lancement du script `test_hacker.py`.
4. **Réaction de l'IDS** : L'alerte CRITICAL apparaît en temps réel sur l'interface Web (moins de 2 secondes).
5. **Isolation** : Le Dashboard confirme que l'équipement malveillant a été mis en statut ISOLATED et ne peut plus nuire.